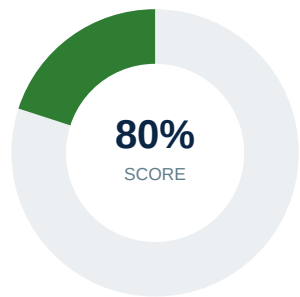


Security Audit Report

Web Application & Infrastructure Assessment



Target: <https://growlity.com/blog/brsr-principles-guide-india>
Prepared for: Client
Scan Date: 02 September 2026, 10:30
Overall Risk Status: **CRITICAL RISK**

Total Checks	Passed	Failed	Critical	High	Medium	Low
52	42	10	1	1	2	6

This report is confidential and intended solely for the addressed client. It summarizes automated findings from an external, black-box security scan and should be supplemented with manual penetration testing for a complete risk assessment.

1. Executive Summary

The assessment identified **10** issue(s) out of **52** checks performed, resulting in a security score of **80%** and an overall risk rating of **CRITICAL RISK**. There are **1 critical** and **1 high** severity finding(s) that should be prioritized for remediation.

2. SSL / TLS & Certificate Audit

Parameter	Result
TLS Version	TLSv1.3
Cipher Suite	TLS_AES_256_GCM_SHA384
Hostname Verification	PASS
Self-Signed	NO
Valid From	Jul 18 05:50:00 2026 GMT
Valid Until	Oct 16 06:49:58 2026 GMT
Days Remaining	44
Issuer	countryName=US, organizationName=Google Trust Services, commonName=WE1
Subject	commonName=growlity.com
Subject Alt. Names (SAN)	growlity.com, *.growlity.com

3. DNS, DNSSEC & Domain Audit

Parameter	Result
A Records	172.67.189.104, 104.21.65.81
AAAA Records	2606:4700:3031::ac43:bd68, 2606:4700:3035::6815:4151
MX Records	10 mx.zoho.com., 20 mx2.zoho.com., 50 mx3.zoho.com.
NS Records	kolton.ns.cloudflare.com., colette.ns.cloudflare.com.
CAA Records	None (finding)
DNSSEC Enabled	YES
WHOIS Registrar	GoDaddy.com, LLC
Domain Expiration	2028-05-26 08:15:37+00:00
Days To Expiry	632

4. Security Issues & Recommendations

Severity	Check	Details	Recommendation
CRITICAL	Website Availability	Website returned HTTP 403.	Verify website availability and server configuration.
HIGH	HTTP to HTTPS Redirect	HTTP does not correctly redirect to HTTPS.	Configure a permanent HTTP to HTTPS redirect.
MEDIUM	X-Frame-Options	X-Frame-Options header is missing.	Configure a proper X-Frame-Options header.
MEDIUM	DNS - CAA Record	No CAA record found - any public CA can issue certs for this domain.	Add a CAA record restricting which Certificate Authorities may issue certificates.
LOW	Information Disclosure - server	Server technology information exposed: cloudflare	Remove unnecessary technology/version information from HTTP headers.
LOW	Security.txt (RFC 9116)	No security.txt file found.	Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
LOW	Cross-Origin-Opener-Policy	Cross-Origin-Opener-Policy header is missing.	Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Resource-Policy	Cross-Origin-Resource-Policy header is missing.	Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Embedder-Policy	Cross-Origin-Embedder-Policy header is missing.	Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
LOW	X-Permitted-Cross-Domain-Policies	X-Permitted-Cross-Domain-Policies header is missing.	Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

5. Successful Security Checks

Check	Severity	Details
TLS Version	INFO	Secure TLS version detected: TLSv1.3
SSL Certificate	INFO	Valid TLS certificate was successfully retrieved.
TLS Cipher	INFO	Negotiated cipher: TLS_AES_256_GCM_SHA384
Certificate Hostname Match	INFO	Certificate hostname matches the requested domain (SAN/CN verified).
Legacy Protocol Support - TLSv1.0	INFO	Server correctly rejects TLSv1.0.
Legacy Protocol Support - TLSv1.1	INFO	Server correctly rejects TLSv1.1.
Protocol Support - TLSv1.2	INFO	Server supports TLSv1.2.
Protocol Support - TLSv1.3	INFO	Server supports TLSv1.3.
HSTS	INFO	Header present: max-age=31536000; includeSubDomains; preload
Content Security Policy	INFO	Header present: frame-ancestors 'self' https://growlity.com
X-Content-Type-Options	INFO	Header present: nosniff
Referrer Policy	INFO	Header present: same-origin, strict-origin-when-cross-origin
Permissions Policy	INFO	Header present: camera=(self), microphone=(self), geolocation=(self), payment=(self), usb=(), interest-cohort=()
CSP Strength	INFO	CSP does not use unsafe-inline, unsafe-eval, or an obvious wildcard source.
HSTS Strength	INFO	HSTS configured with sufficient max-age, includeSubDomains and preload.
Clickjacking Protection	INFO	Framing is restricted via X-Frame-Options and/or CSP frame-ancestors.
CORS Configuration	INFO	No permissive CORS wildcard detected.
Cookie Security	INFO	No cookies were set during the initial response.
HTTP Methods	INFO	No explicit Allow header exposing methods.
Sensitive Path Exposure	INFO	No tested sensitive paths returned HTTP 200.
Sensitive / Internal Link Exposure	INFO	No internal, staging or admin/config links were found in the page's outbound links.
Mixed Content	INFO	No obvious HTTP resource references detected.
Cache-Control	INFO	Cache-Control: private, max-age=0, no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Subresource Integrity (SRI)	INFO	No external scripts missing SRI (or none detected).
Robots.txt	INFO	No robots.txt found (nothing to disclose).
HTTP Protocol Version	INFO	Negotiated protocol (via requests/urllib3): HTTP/1.1. Server advertises Alt-Svc: h3=":443"; ma=86400 (h3/h2 support).
DNS - Name Servers	INFO	NS records: kolton.ns.cloudflare.com., colette.ns.cloudflare.com.
DNS - SPF Record	INFO	SPF record found in TXT records.
DNSSEC	INFO	DNSSEC is enabled for this domain.
Domain Expiry (WHOIS)	INFO	Domain registered until 2028-05-26 08:15:37+00:00 (632 days remaining).
Certificate Transparency Logs	INFO	Could not retrieve CT log data (crt.sh unavailable or rate-limited).
Version Disclosure	INFO	No specific software version numbers were disclosed in response headers.
HTTP TRACE Method	INFO	Server does not permit TRACE requests (HTTP 405).
Directory Listing	INFO	No directory listing detected on commonly probed paths.
Open Redirect	INFO	No open redirect behavior detected on commonly probed parameters.
Password Field Autocomplete	INFO	No password input fields detected on this page.
Exposed Secrets in Page Source	INFO	No obvious credential/key patterns detected in page source.
Cryptomining / Known Malicious Script Source	INFO	No script tags referencing known malicious/cryptomining domains were found.
Obfuscated Script / Hidden Iframe Patterns	INFO	No obfuscated script or hidden-iframe patterns detected in page source.
Unsolicited Cross-Domain Redirect	INFO	No meta-refresh redirect detected.

Check	Severity	Details
Self Signed Certificate	INFO	Certificate is not self-signed.
Certificate Expiry	INFO	Certificate has 44 days remaining.

6. Sensitive Path Enumeration

Path	HTTP Status	Risk	Exposed
.env	403	INFO	NO
.git/config	403	INFO	NO
config.json	403	INFO	NO
config.php	403	INFO	NO
debug	403	INFO	NO
actuator	403	INFO	NO
phpinfo.php	403	INFO	NO
server-status	403	INFO	NO
backup.zip	403	INFO	NO
backup.sql	403	INFO	NO
.DS_Store	403	INFO	NO
composer.json	403	INFO	NO
package-lock.json	403	INFO	NO
webpack.config.js	403	INFO	NO
docker-compose.yml	403	INFO	NO
database.sql	403	INFO	NO
dump.sql	403	INFO	NO
admin	403	INFO	NO
admin/	403	INFO	NO
debug.log	403	INFO	NO
error.log	403	INFO	NO
swagger.json	403	INFO	NO
swagger-ui.html	403	INFO	NO
graphql	403	INFO	NO
.htaccess	403	INFO	NO
wp-config.php	403	INFO	NO
.well-known/security.txt	403	INFO	NO
.git/HEAD	403	INFO	NO
.env.local	403	INFO	NO
.env.production	403	INFO	NO
.env.backup	403	INFO	NO
credentials.json	403	INFO	NO
secrets.yml	403	INFO	NO
secrets.yaml	403	INFO	NO
.aws/credentials	403	INFO	NO
id_rsa	403	INFO	NO
id_rsa.pub	403	INFO	NO
.npmrc	403	INFO	NO
.idea/workspace.xml	403	INFO	NO
.vscode/settings.json	403	INFO	NO
web.config	403	INFO	NO
vendor/composer/installed.json	403	INFO	NO
storage/logs/laravel.log	403	INFO	NO

Path	HTTP Status	Risk	Exposed
wp-content/debug.log	403	INFO	NO
.well-known/openid-configuration	403	INFO	NO
server.key	403	INFO	NO
server.pem	403	INFO	NO

7. Cookie Security

No cookies were observed during this scan - the initial response did not include any **Set-Cookie** headers, so there is nothing to assess here.

8. Prioritized Recommendations

1. Verify website availability and server configuration.
2. Configure a proper X-Frame-Options header.
3. Remove unnecessary technology/version information from HTTP headers.
4. Configure a permanent HTTP to HTTPS redirect.
5. Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
6. Add a CAA record restricting which Certificate Authorities may issue certificates.
7. Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
8. Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
9. Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
10. Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

9. AI Overall Review & Suggestions

<think>

Thinking Process:

1. **Deconstruct the Input:**

* Target: `https://growlity.com/blog/brsr-principles-guide-india`

* Score: 80% (Wait, this seems contradictory to the risk status. Usually, 80% is good, but "CRITICAL_RISK" suggests something is very wrong. I need to highlight this discrepancy or explain it. The score might be based on passed checks, but a critical failure like 403 overrides the score in terms of business impact.)

* Risk Status: CRITICAL_RISK.

* Checks: 52 total, 42 passed, 10 failed.

* Failures:

* CRITICAL: Website Availability (HTTP 403).

* HIGH: HTTP to HTTPS Redirect.

* MEDIUM: X-Frame-Options missing.

* MEDIUM: DNS CAA Record missing.

* LOW: Server info exposed (Cloudflare).

* LOW: No security.txt.

* LOW: COOP missing.

* LOW: CORP missing.

* LOW: COEP missing.

* LOW: X-Permitted-Cross-Domain-Policies missing.

2. **Drafting - Section by Section (Mental Outline & Plain Language Translation):**

* **Overall Security Posture:**

* The score is 80%, which looks okay, but the status is CRITICAL. Why? Because the site is returning a 403 Forbidden. If the site is down or blocked, the score is irrelevant to the user. The posture is "Broken" or "Unavailable" despite passing many technical checks.

* **Drafting:** The security audit reveals a contradictory state where the technical configuration scores 80%, but the overall risk is critical due to a fundamental availability failure. While the underlying infrastructure passes most security checks, the website is currently returning an HTTP 403 Forbidden error, meaning legitimate users cannot access the content. This availability issue completely negates the positive score, as a secure site that no one can reach provides no business value.

* **Business-Critical Risks:**

* What matters most?

* 1. 403 Error: Business stops. No traffic, no SEO, no revenue. This is the #1 risk.

* 2. HTTP to HTTPS Redirect: If HTTP doesn't redirect to HTTPS, users might be sent to an insecure version (if it exists) or get errors. It's a HIGH risk. It affects trust and data security.

* 3. X-Frame-Options: Clickjacking risk. Medium severity, but good to mention for business context (brand reputation, user safety).

***Drafting:** The most urgent business risk is the HTTP 403 error, which blocks all access to the blog and likely the wider site, resulting in immediate loss of traffic, SEO rankings, and potential revenue. Secondly, the failure to redirect HTTP traffic to HTTPS poses a significant risk; users typing the domain without 'https' may encounter errors or be exposed to insecure connections, undermining trust and potentially leaking data. Additionally, the missing X-Frame-Options header leaves the site vulnerable to clickjacking attacks, where malicious actors could trick users into interacting with hidden frames, damaging brand reputation and user safety.

***Prioritized Remediation Order:**

*** Order:**

- * 1. Fix 403. (Critical).
- * 2. Fix HTTP->HTTPS. (High).
- * 3. X-Frame-Options & CAA. (Medium).
- * 4. Low severity headers. (Low).

***Drafting:** Remediation must begin immediately with resolving the HTTP 403 error by reviewing firewall rules, Cloudflare access settings, or server configuration to ensure the site is publicly accessible. Once availability is restored, address the HTTP to HTTPS redirect to enforce secure connections for all visitors. Following that, implement the X-Frame-Options header to prevent clickjacking and add a DNS CAA record to restrict which certificate authorities can issue certificates for the domain. Finally, address the low-severity missing headers and information disclosure issues to harden the configuration further.

***Quick Wins:**

*** What's low effort, high impact?**

***Server Info:** "cloudflare" is exposed. This is usually a header like `Server: cloudflare`. Hiding this is often a config toggle. Low effort.

***Security.txt:** Creating a file is easy. Low effort.

***Headers:** Adding headers like X-Frame-Options is often a one-line config change or a Cloudflare setting.

***Note:** The 403 is likely a config error, but fixing it might be "high effort" if the root cause is unknown. However, usually, a 403 is a misconfiguration that can be fixed quickly once found. But "Quick Wins" usually refers to things that are easy to do ***now**.

***Best Quick Wins:** Adding headers (X-Frame-Options, COOP, etc.) via Cloudflare is very fast. Adding CAA record is fast. Creating security.txt is fast. Hiding server header is fast.

***Drafting:** Several quick wins exist that require minimal effort but improve the security profile. You can immediately add the missing security headers, such as X-Frame-Options and the Cross-Origin policies, directly through your Cloudflare dashboard without touching server code. Adding a DNS CAA record and creating a simple security.txt file are also rapid tasks that enhance trust and compliance. Finally, configuring Cloudflare to suppress the server technology header is a simple toggle that reduces information leakage.

3. ****Review and Refine (Self-Correction/Simulation):****

***Critique:** Did I use markdown headers? No.

***Critique:** Did I use bullet symbols? The prompt says "no bullet symbols other than plain text". This usually means I can use plain text bullets like `>` or `\*` if they are part of the text flow, or just paragraphs. The prompt asks for "no bullet symbols", which might mean "don't use markdown bullets". I should write in paragraphs or use plain text separators. The prompt says "no bullet symbols other than plain text". This is slightly ambiguous. It likely means "Do not use markdown formatting for bullets, use plain text characters if needed, or just paragraphs." To be safe, I'll use paragraphs and perhaps plain text dashes if necessary, but the instruction "no bullet symbols" suggests avoiding lists entirely or using very plain text. I'll stick to paragraphs to be safest, or use plain text dashes like `>` which are characters, not markdown symbols. Actually, "no bullet symbols other than plain text" often means "You can use `>` but not `\*` or `>` or markdown lists." I'll use plain text paragraphs to ensure compliance.

* *Refinement on "Quick Wins":* The 403 is the biggest issue. Is it a quick win? If it's a Cloudflare WAF rule blocking the scanner, it might be a quick fix. But I shouldn't assume. I'll focus the quick wins on the headers and DNS.

* *Refinement on Score vs Risk:* I mentioned the contradiction. This is good analysis. The client might be confused why 80% is Critical. Explaining that 403 breaks everything is key.

* *Refinement on Tone:* Concise, plain language.

* *Final Polish (Mental Text Structure):*

The audit presents a critical discrepancy: while the technical configuration achieves an 80% score, the overall risk is critical because the website is currently inaccessible. The site returns an HTTP 403 Forbidden error, which blocks all user access and renders the security score irrelevant to business operations. A secure website that cannot be reached provides no value, and this availability failure likely impacts search engine rankings, user trust, and revenue immediately.

The primary business risk is the complete loss of availability due to the 403 error. This must be resolved before any other security measure matters. The second most critical issue is the failure to redirect HTTP traffic to HTTPS, which risks exposing users to insecure connections or errors when they visit the site without explicitly typing 'https'. Additionally, the missing X-Frame-Options header leaves the site vulnerable to clickjacking, where attackers could trick users into performing unintended actions, posing a risk to user safety and brand reputation.

Remediation should follow a strict priority order. First, investigate and resolve the HTTP 403 error by checking firewall rules, Cloudflare access settings, or server configurations to restore public access. Second, enforce HTTP to HTTPS redirection to ensure all traffic is encrypted. Third, implement the X-Frame-Options header and add a DNS CAA record to prevent clickjacking and restrict certificate issuance. Finally, address the remaining low-severity findings, such as missing cross-origin headers and server information disclosure, to complete the hardening process.

There are several quick wins that offer high impact with low effort. You can add the missing security headers, including X-Frame-Options and the Cross-Origin policies, directly through your Cloudflare dashboard without modifying server code. Adding a DNS CAA record and creating a standard security.txt file are also rapid tasks that improve compliance and trust. Additionally, configuring Cloudflare to hide the server technology header is a simple

Generated by TestPilot-AI Security Audit - automated scan results should be validated by a qualified security professional before remediation sign-off.